

Identity Governance Validation Engine

Microsoft Azure · Entra ID · PowerShell · v2.0

26 rules · 6 categories

3 scan modes

5 suppression chains

48 identities evaluated

March 2026

EXTERNAL DATA SOURCES

Microsoft Graph API

- User.Read.All
- Group.Read.All
- GroupMember.Read.All
- UserAuthenticationMethod.Read.All
- **AuditLog.Read.All** — **required for sign-in data**
- signInActivity requires Entra P1/P2

Azure ARM API

- Az.Accounts · Az.Resources
- All accessible subscriptions (subscription-agnostic by default)
- Role assignments at Sub / RG / Resource scope
- SubscriptionFilter param available (opt-in restriction)
- Session expiry detected before ARM calls

HR System

- Upstream via SCIM / Entra HR Provisioning
- Populates EmployeeType · EmployeeId
- Not called directly by the engine
- Data consumed via Graph user properties
- HR sync gaps surface as IDENT-003 findings

COLLECTION LAYER

IdentityCollector.ps1

Graph only · fact-only · no rule logic

- Get-IdentityUsers
- Get-IdentityGroups
- Get-IdentityMemberships
- Resolve-EmploymentStatus
- Resolve-MfaState
- Set-UserPrivilegeFlag
- Get-IdentitySnapshot

→ IdentitySnapshot { Users[] · Groups[] · MembershipMap[] · CollectedAt }

RbacCollector.ps1

ARM only · sequential per subscription · fact-only

- Get-RbacSnapshot
- Get-SubscriptionRoleAssignments
- Resolve-RbacScopeType
- Resolve-RbacSubscriptionId
- Write-RbacCollectionError

→ RbacSnapshot { RoleAssignments[] · SubscriptionsEnumerated[] · CollectedAt }

RULE EVALUATION LAYER

FindingSchema.ps1

New-ComplianceFinding

Invoke-SuppressionPass

shared schema · all processors must use this · no processor builds findings manually

IDRuleProcessor.ps1

18 rules

IDENTITY

- IDENT-001** Disabled account in privileged group **BLOCK** 100
- IDENT-002** No UPN or malformed UPN **BLOCK** 70
- IDENT-003** Employment status not Active / Unknown 40
- JOIN-001** Joiner: no employment record **BLOCK** 100
- JOIN-002** Joiner: job title → restricted group **BLOCK** 80

ACCESS

- ACCESS-001** Intern/contractor in manager group **BLOCK** 80
- ACCESS-002** Terminated account with group memberships **BLOCK** 100
- ACCESS-003** Mixed priv + standard group membership 75
- ENT-001** Employment type not permitted for group 70
- ENT-002** Employment type → privileged group block **BLOCK** 100
- ENT-003** Group not in entitlement model 15

ARCHITECTURE

- ARCH-001** Tier-0 asset managed by non-Tier-0 account **BLOCK** 100
- ARCH-002** Admin account used for day-to-day ops 70
- ARCH-003** Service account in interactive user groups 65

HYGIENE

- HYG-001** Inactive >90 days 35
- HYG-002** Inactive >180 days (stale) 65
- HYG-003** Password not changed >365 days 40
- HYG-004** Privileged account — no MFA registered **BLOCK** 100

Suppression: HYG-003 → suppresses HYG-001
ENT-002 → suppresses ACCESS-001

RbacRuleProcessor.ps1

3 rules

RBAC

- RBAC-001** Direct Azure role assignment — must be group-based 80
- RBAC-002** Privileged role at subscription scope 75
- RBAC-003** Owner role directly assigned to user at any scope **BLOCK** 100

RBAC-003 → suppresses RBAC-002 + RBAC-001
Scope-aware: same entity + scope + role key
Shared Invoke-SuppressionPass after scope-aware pass

FUNCTIONS

- Evaluate-DirectRoleAssignments
- Resolve-RbacEntityType
- Invoke-RbacRuleEngine

SCOPE TYPES DETECTED

- Subscription
- ResourceGroup
- Resource
- ManagementGroup
- Unknown

SKIPPED IN

PreProvision mode
(no ARM calls)

CorrelationRuleProcessor.ps1

5 rules · cross-plane

CORRELATION — REQUIRES BOTH PLANES

- CORR-001** Priv-tier group + Owner at subscription scope **BLOCK** 100
- CORR-002** Disabled account + active RBAC assignments **BLOCK** 100
- CORR-003** Non-FTE holds privileged RBAC role **BLOCK** 85
- CORR-004** Priv-tier identity + direct Azure assignment 75
- CORR-005** Inactive >90 days + active RBAC roles 70

CORR-001 → suppresses CORR-004
CORR-001 is strict superset of CORR-004
Fires only when CORR-001 does not fire

FUNCTIONS

- Evaluate-CrossPlaneExposure
- Build-CorrelationRbacIndex
- Invoke-CorrelationRuleEngine

SKIPPED IN

PreProvision mode
(requires RbacSnapshot)

CLASSIFICATION LAYER

RiskClassifier.ps1

no Azure API calls · no rule logic · pure classification

FullScan Mode

- Entities All users + RBAC principals
- Rules All 26 — all 6 categories
- Output **EntityRiskStates[] + Summary()**
- Status Compliant · NonCompliant · Blocking
- RiskScore Min(RawSum/900, 100, 100)
- Density Score + ViolationCount
- Hygiene Separated from compliance gate
- Invariant Compliant + ViolationCount = 0

PreProvision Mode

- Entities Single user (TargetUserId)
- Rules Identity + Access only
- Gate Blocking findings only
- Output **Decision: Pass | Fail**
- Returns BlockingCount · Reasons[]
- RiskScore Not calculated
- RBAC No ARM calls — skipped
- JML hook **Primary integration point ↓**

DriftOnly Mode

- Entities Drift findings only
- Rules Arch · RBAC · Access · Correlation
- Skips Identity + Hygiene rules
- Output **TotalEntitiesWithDrift**
- Schedule Daily between FullScan runs
- Purpose Detect structural changes fast
- RBAC ARM calls run (same as FullScan)
- Compare StoreDriftState for trending

OUTPUT LAYER · REPORTGENERATOR.PS1

JSON Report

- Full EntityRiskStates[]
- Summary() object
- Mode + ClassifiedAt
- ExportJson switch

CSV Report

- 24 columns per finding
- 1 row per entity + finding
- SIEM-ready timestamps
- ExportCsv switch

Drift State

- LastRun_DriftState.json
- RiskTrend vs prior run
- Cross-run comparisons
- StoreDriftState switch

Console

- Formatted compliance summary
- Top risk spotlight
- All modes
- Always active

Error Log

- Non-fatal collection errors
- Timestamp · Source · Detail
- Per-group / per-sub failures
- ErrorLogPath param

JML INTEGRATION LAYER

JML Orchestration Layer · PreProvision as gate · Engine called via -Mode PreProvision -TargetUserId {GUID}

IN DEVELOPMENT

Joiner

- Trigger HR creates record → event fires
- Engine PreProvision(TargetUserId)
- Pass **Provision group memberships**
- Fail **Block + surface Reasons[] for ticket**
- Rules JOIN-001 · JOIN-002 · ENT-002

Mover

- Trigger Role / department change event
- Engine Revoke old groups → PreProvision
- Pass **Assign new role group memberships**
- Fail **Block + surface Reasons[]**
- Follow-up **DriftOnly post-move to confirm**

Leaver

- Trigger Termination event from HR
- Action Disable account + revoke groups
- Verify **FullScan post-revocation**
- ACCESS-002 **Fire = revocation incomplete**
- CORR-002 **Fire = RBAC not fully revoked**

RISK SCORE **RiskScore = Min(RawWeightSum / 900 × 100 , 100.0)** Fixed cap 900 · Cross-run comparable · Not tenant-relative · RiskDensity = Score + ViolationCount · Hygiene separated from compliance gate

SEVERITY ● Critical — w=100 blocking ● High — w=65-85 ● Medium — w=35-40 ● Low — w=15 BLOCK badge = Decision=Fail in PreProvision · ComplianceStatus=Blocking in FullScan

26 rules · 6 categories · 5 suppression chains · v2.0 · March 2026